

Statement of Applicability — Implementation Guide

1. Purpose

The Statement of Applicability (SoA) records the necessary controls, justification for inclusion, implementation status and relationship to the organization's ISMS. It provides traceability between risk treatment and security controls.

2. How this SoA was built

The simulated SoA considers TechNova's SaaS business, cloud dependency, customer information, software development, employees, suppliers, physical facilities and identified information-security risks.

3. Applicability principle

A control is not marked applicable simply because it appears in Annex A. Applicability is determined by the organization's context, risk treatment, requirements, business needs and other relevant considerations. Conversely, a control can be applicable even where its implementation is still planned.

4. Traceability

Risk Register → Risk Treatment Plan → Selected Control → SoA → Control Implementation → Evidence → Internal Audit.

5. Auditor checks

An auditor will typically test whether the SoA is consistent with the risk assessment and treatment process, whether justifications are credible, whether implementation status is accurate, and whether evidence supports the stated status.

6. Important portfolio limitation

This is a simulated project. The control names and references are provided for ISO/IEC 27001:2022 portfolio practice; actual certification work should use the organization's licensed standard, current requirements and verified evidence.